

# Gap Analysis & Remediation Roadmap

*Plan of Action & Milestones (POA&M) — Nexora Solutions Pvt Ltd (Hypothetical SME)*

## 1. Purpose and Method

This document consolidates every open gap identified across the Statement of Applicability (controls marked ‘Partial’ or ‘No’) and the Internal Audit Checklist (non-conformities and observations) into a single, prioritized action plan. This follows the structure of a Plan of Action & Milestones (POA&M), a format widely used in US federal and contractor GRC practice (e.g. FedRAMP), and serves the same purpose as an ISO 27001 Risk Treatment Plan update following an internal audit: it turns findings into owned, time-bound commitments rather than leaving them as static documentation.

Priority was assigned as follows: Critical items are confirmed non-conformities tied to a High-rated risk in the Risk Register and require action within 30–60 days; High items are significant SoA gaps without a confirmed active exploit path; Medium items are process gaps that reduce long-term resilience; Low items are governance maturity improvements appropriate once the above are resolved.

## 2. Remediation Roadmap

| ID     | Source                       | Finding / Gap                                                                                                              | Priority | Remediation Action                                                                                                          | Owner            | Target  |
|--------|------------------------------|----------------------------------------------------------------------------------------------------------------------------|----------|-----------------------------------------------------------------------------------------------------------------------------|------------------|---------|
| POA-01 | Internal Audit — Finding #4  | VPN remote-access gateway has no Multi-Factor Authentication enabled (Risk 8, High).                                       | Critical | Enable MFA on the VPN gateway for all users; disable legacy single-factor login.                                            | IT Administrator | 30 days |
| POA-02 | Internal Audit — Finding #12 | Client source code repositories lack branch protection rules (Risk 2, High).                                               | Critical | Enable branch protection (required reviews, no direct pushes to main) on all client repositories.                           | Engineering Lead | 30 days |
| POA-03 | Internal Audit — Finding #14 | Privileged/administrative accounts are shared rather than individually assigned; no PAM solution in place (Risk 15, High). | Critical | Deploy a Privileged Access Management (PAM) solution; migrate all admin accounts to unique, individually-owned credentials. | IT Administrator | 60 days |
| POA-04 | Internal Audit — Finding #8  | Backups are stored on the same network as production with no air-gap; no restoration test on record (Risk 11, High).       | Critical | Implement offline/immutable backup storage; schedule and document a quarterly restoration test.                             | IT Administrator | 60 days |

| ID     | Source                                     | Finding / Gap                                                                                                | Priority | Remediation Action                                                                                                                                                      | Owner                 | Target    |
|--------|--------------------------------------------|--------------------------------------------------------------------------------------------------------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|-----------|
| POA-05 | SoA — Controls 5.19, 5.20, 5.22            | No formal supplier information-security assessment process (supplier relationships, agreements, monitoring). | High     | Draft a Supplier Security Policy; require security addenda in new supplier contracts; assess existing critical suppliers (cloud hosting, payroll processor).            | CTO / Procurement     | 90 days   |
| POA-06 | SoA — Control 5.30 / Policy 1.5            | No ICT business continuity or disaster recovery plan exists.                                                 | High     | Draft a Business Continuity Policy covering recovery time/point objectives for critical systems, aligned to the CSF 'Recover' function gap already noted in the Policy. | CTO                   | 90 days   |
| POA-07 | SoA — Control 5.12, 5.13                   | No information classification scheme (e.g. Public/Internal/Confidential) is defined or applied.              | Medium   | Define a 3-tier classification scheme; apply labelling to key repositories and the CRM database first.                                                                  | IT Security Lead      | 90 days   |
| POA-08 | SoA — Control 6.1                          | No pre-employment screening process for new hires, particularly for privileged roles.                        | Medium   | Introduce baseline background screening for roles with administrative or client-data access.                                                                            | HR                    | 90 days   |
| POA-09 | Internal Audit — Finding #7 (Observation)  | Vulnerability scanning was performed once, with no recurring schedule defined.                               | Medium   | Establish a documented quarterly vulnerability scanning cadence with tracked remediation SLAs by severity.                                                              | IT Security Lead      | 60 days   |
| POA-10 | Internal Audit — Finding #13 (Observation) | Security awareness training is not recurring; only a one-time phishing simulation has been run.              | Medium   | Establish an annual security awareness training program with periodic phishing simulations.                                                                             | HR / IT Security Lead | 120 days  |
| POA-11 | SoA — Control 5.35                         | No independent (third-party) review of the information security program has been conducted.                  | Low      | Schedule an annual independent review, e.g. via an external auditor or qualified consultant, once Critical/High items above are closed.                                 | CTO                   | 12 months |
| POA-12 | Internal Audit — Finding #15 (Observation) | This is the organization's first internal audit cycle; no recurring audit calendar is documented.            | Low      | Formalize an annual (minimum) internal audit calendar per Clause 9.2, with scope rotation across control themes.                                                        | IT Security Lead      | 6 months  |

### 3. Summary

Of 12 items tracked: 4 Critical, 2 High, 4 Medium, and 2 Low priority. The four Critical items correspond directly to the four non-conformities raised in the Internal Audit Checklist and should be closed first, as each maps to a High-rated risk in the Risk Register (VPN MFA, repository branch protection, privileged account management, and backup resilience).

- Recommended review cadence: Critical/High items reviewed bi-weekly until closed; Medium/Low items reviewed at the next scheduled internal audit cycle.
- Each closed item should be re-verified at the next Internal Audit cycle before being marked complete, consistent with real audit practice — self-reported closure without re-testing is not considered sufficient evidence.
- Once all Critical and High items are closed, Nexora's SoA and Risk Register should be formally revised to reflect the improved control posture, and risk scores re-calculated accordingly.